

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

Resource 01

AI Governance Readiness Checklist

Baseline Controls for Responsible AI Adoption

NIST AI RMF 1.0 | ISO/IEC 42001:2023

Resource ID	TSEC-AI-01
Category	AI Governance
Framework Alignment	NIST AI RMF 1.0 (Govern/Map/Measure/Manage); ISO/IEC 42001:2023 AIMS
Version	1.1
Published	July 2026
Intended Audience	CISOs, Compliance Officers, AI Program Owners, IT & Data Leaders
Prepared By	TSEC Risk & Cyber Advisory LLC
Classification	Public — For Educational & Advisory Use

TSEC Compliance Resource Library — www.tsecgrc.com/resources

Table of Contents

Table of Contents.....	2
Executive Summary	3
Introduction	3
AI Governance Overview	4
NIST AI RMF 1.0: Four Functions.....	4
ISO/IEC 42001:2023: AI Management System (AIMS).....	4
Framework Crosswalk	5
Roles & Responsibilities.....	5
Governance Checklist.....	6
Policy & Accountability	6
Inventory & Use-Case Register	6
Lifecycle Governance.....	7
Risk Management	8
Risk Identification	8
Risk Treatment.....	8
Security & Privacy.....	8
Data Protection.....	8
Access & Identity.....	9
Privacy & Individual Rights	9
Monitoring	9
Maturity Self-Score	11
Common Pitfalls.....	11
Recommendations	12
Next Steps	12
Sample AI Acceptable Use Policy Outline	12
Glossary of Key Terms.....	13
About TSEC & Next Steps	13

Executive Summary

Organizations across every sector are adopting artificial intelligence faster than they are governing it. Machine learning models, generative AI copilots, and increasingly autonomous agents are now embedded in underwriting, customer support, hiring, diagnostics, and internal productivity tools — often introduced by individual teams before a governance function is even aware the system exists.

This checklist gives compliance, security, and IT leaders a practical, complete baseline for assessing AI governance readiness. It is organized around the two most widely adopted AI governance references available today: the NIST AI Risk Management Framework (AI RMF 1.0), which structures AI risk activity into four functions — Govern, Map, Measure, and Manage — and ISO/IEC 42001:2023, the first international management-system standard for AI, which mirrors the plan-do-check-act structure familiar from ISO 27001 and ISO 9001.

Use this document as a gap-assessment tool: work through each checklist section, mark items as in place, partially in place, or not started, score your organization using the maturity rubric in this document, and use the Recommendations and Next Steps sections to sequence remediation. Organizations with an existing ISO 27001 or SOC 2 program will recognize much of the underlying structure — AI governance extends, rather than replaces, an organization's existing risk management system.

How to Use This Document

Read the AI Governance Overview to understand the two reference frameworks this checklist is built on.

Work section by section through the Governance, Risk Management, Security & Privacy, and Monitoring checklists.

Score each section using the Maturity Self-Score rubric and total your organization's readiness level.

Assign owners and target dates to open items using the Roles & Responsibilities table as a starting point.

Introduction

AI governance is the set of policies, roles, processes, and technical controls an organization uses to ensure that AI systems are developed, procured, and operated in a way that is safe, compliant, and aligned with business objectives. It is not a single control or a one-time assessment — it is an ongoing management system that spans the full AI lifecycle, from use-case intake through decommissioning.

This checklist is intended for organizations at the early-to-intermediate stage of formalizing AI governance: those that have deployed or are piloting AI-enabled tools (including third-party

SaaS products with embedded AI features and generative AI assistants) but do not yet have a documented governance program. It assumes no prior AI-specific control framework, and maps each requirement back to a recognized standard so that findings can be defended to auditors, regulators, cyber-insurance underwriters, and enterprise customers during vendor due diligence.

A note on scope: this checklist addresses governance of AI as a business function — how an organization decides to build, buy, and operate AI responsibly. It intentionally does not attempt to teach data science or machine learning engineering practice; where technical depth is needed (model validation methodology, adversarial testing), the checklist points to the specific control expectation rather than the underlying technique.

AI Governance Overview

NIST AI RMF 1.0: Four Functions

The NIST AI Risk Management Framework (NIST AI 100-1) is voluntary, cross-sector guidance built around four functions that operate continuously and iteratively rather than in strict sequence:

- **Govern** — Establishes organizational risk culture, accountability, and policy across the AI lifecycle. Govern is cross-cutting: it informs and is informed by the other three functions, and typically comes first in a maturing program.
- **Map** — Establishes context: what the AI system does, who it affects, what data it uses, and what could go wrong. Map produces the risk inventory that Measure and Manage act on.
- **Measure** — Applies quantitative and qualitative methods to test, benchmark, and monitor identified risks — accuracy, bias, robustness, and security testing all live here.
- **Manage** — Allocates resources to risk response (mitigate, transfer, avoid, or accept), documents residual risk, and defines incident response and recovery procedures for AI-specific failures.

ISO/IEC 42001:2023: AI Management System (AIMS)

ISO/IEC 42001 is structured like other ISO management-system standards, with clauses covering organizational context, leadership, planning, support, operation, performance evaluation, and improvement, plus Annex A, a set of AI-specific controls covering topics such as AI system impact assessment, data quality for AI, third-party and supplier management, and transparency to affected parties. Organizations already certified to ISO 27001 can extend their existing Information Security Management System rather than building an AI program from scratch — many of the required roles (management review, internal audit, document control, risk treatment) are the same muscle, applied to a new risk domain.

Why Both Frameworks Matter

NIST AI RMF is the de facto reference for U.S. regulators, federal contractors, and state AI disclosure laws.

ISO/IEC 42001 is the certifiable standard increasingly requested in enterprise vendor security questionnaires and RFPs, particularly for SaaS and FinTech vendors selling into regulated buyers.

Neither framework prescribes specific tools — both require the organization to define and evidence its own governance decisions.

Framework Crosswalk

The table below maps each section of this checklist to the corresponding NIST AI RMF function and the closest ISO/IEC 42001 clause or Annex A control area, so findings can be traced back to a specific framework reference during an audit or customer review.

Checklist Section	NIST AI RMF Function	ISO/IEC 42001 Reference
Policy & Accountability	Govern	Clause 5 (Leadership) / Clause 5.3 (Roles)
Inventory & Use-Case Register	Map	Annex A.6.2 (AI system inventory)
Lifecycle Governance	Govern / Manage	Clause 8 (Operation) / Annex A.6 (AI lifecycle)
Risk Identification & Treatment	Map / Measure	Clause 6.1 (Risk & Opportunity) / Annex A.5 (Risk assessment)
Data Protection	Manage	Annex A.7 (Data for AI systems)
Access & Identity	Manage	Annex A.9 (Third-party & operational controls, cross-referenced to ISO 27001 A.5.15–A.5.18)
Privacy & Individual Rights	Map / Manage	Annex A.8 (Impact assessment) / Annex A.10 (Transparency)
Monitoring	Measure / Manage	Clause 9 (Performance Evaluation) / Clause 10 (Improvement)

Roles & Responsibilities

AI governance fails most often not because the wrong controls were chosen, but because no one was clearly accountable for them. Assign each area below to a specific role before beginning remediation — for smaller organizations, a single person may hold several of these responsibilities.

Function	Typical Owner	Core Responsibility
Executive Sponsor	CISO, CTO, or COO	Approves AI governance policy; owns risk acceptance for Critical-tier systems

Function	Typical Owner	Core Responsibility
AI Governance Lead	Compliance Officer or dedicated AI Program Owner	Runs the intake process, maintains the inventory, coordinates assessments
Data / ML Engineering	Data Science or Engineering Lead	Implements technical controls; supports Measure-function testing
Legal & Compliance	General Counsel or Compliance function	Reviews regulatory exposure; approves contract language for AI vendors
IT & Security	CISO or IT Director	Implements access controls, monitoring, and incident response
Business Unit Leads	Department heads adopting AI tools	Submit use cases through intake; own day-to-day acceptable use within their teams

Governance Checklist

Policy & Accountability

A governance program without a named owner and an approved policy tends to stay informal indefinitely — this is the section most organizations should complete first.

- ☐ A written AI governance policy exists and has been approved by an executive sponsor (CISO, CTO, or equivalent).
- ☐ A designated owner (individual or committee) is accountable for AI risk decisions across the organization.
- ☐ The policy defines what counts as an "AI system" for governance purposes, including embedded AI features in third-party SaaS tools.
- ☐ Roles and responsibilities are documented for AI use-case intake, approval, and periodic review.
- ☐ A process exists for employees to request approval before adopting a new AI tool or feature.
- ☐ The policy is reviewed and re-approved on a defined cadence (recommended: annually, or upon material regulatory change).

Inventory & Use-Case Register

- ☐ A current inventory of all AI systems in use exists, including internally built models, embedded vendor features, and generative AI tools.
- ☐ Each inventoried system records its business purpose, data inputs, deployment context, and risk classification.
- ☐ The inventory is reviewed and updated on a defined cadence (recommended: quarterly).

- ☐ High-risk use cases (e.g., those affecting hiring, credit, healthcare, or other consequential decisions) are flagged for enhanced review.
- ☐ The inventory records the model/vendor version in use, so that material changes trigger a re-review rather than going unnoticed.

Lifecycle Governance

- ☐ New AI use cases go through a documented intake and approval workflow before production deployment.
- ☐ Model and system changes (retraining, fine-tuning, prompt/version updates) trigger a re-review proportional to risk.
- ☐ A decommissioning process exists for retiring AI systems, including data disposition.
- ☐ Governance requirements are included in AI-related procurement and contracting templates.
- ☐ A rollback or fallback plan exists for Critical-tier systems in case an AI feature must be disabled quickly.

Risk Management

Risk management activity should map cleanly to the NIST AI RMF Map and Measure functions: identify what could go wrong, then test whether it is actually happening.

Risk Identification

- ☐ AI-specific risks are assessed separately from general IT risk — bias, hallucination/confabulation, model drift, and explainability are evaluated where relevant.
- ☐ Risk assessments consider downstream impact on individuals (employees, customers, patients, applicants), not only technical failure modes.
- ☐ Third-party and embedded-vendor AI features are included in the organization’s risk register, not treated as out of scope because "the vendor owns the model."
- ☐ Risk ratings are documented using a consistent scale (e.g., low/medium/high/critical) tied to likelihood and impact.

Risk Tier	Example Use Case	Minimum Control Expectation
Critical	Credit decisions, clinical triage, automated hiring screens	Human-in-the-loop review, documented impact assessment, bias testing, audit trail
High	Customer-facing chatbots handling PII, fraud scoring	Access controls, monitoring, incident response plan, vendor due diligence
Moderate	Internal analytics copilots, code-generation assistants	Usage policy, data handling guardrails, periodic review
Low	Non-sensitive productivity tools (scheduling, summarization of public content)	Standard acceptable-use policy

Risk Treatment

- ☐ A defined process exists to mitigate, transfer, avoid, or formally accept identified AI risks.
- ☐ Residual risk after mitigation is documented and signed off by an accountable owner.
- ☐ Risk treatment decisions are revisited when the underlying system or its context changes materially.

Security & Privacy

AI systems introduce security and privacy considerations beyond traditional application security — most notably around what data reaches the model, and what the model can be manipulated into revealing.

Data Protection

- ☐ Data classification policy explicitly addresses what categories of data (PII, PHI, financial, trade secret) may or may not be submitted to AI tools, including public generative AI chat interfaces.
- ☐ Data used for model training or fine-tuning is inventoried, and consent/legal basis is documented where personal data is involved.
- ☐ Retention and deletion requirements for prompts, outputs, and logs are defined and enforced.
- ☐ Encryption in transit and at rest is applied to AI-related data stores consistent with the organization's existing security baseline.

Access & Identity

- ☐ Access to AI administration consoles, model configuration, and training data is restricted on a least-privilege basis.
- ☐ AI agents and service accounts with system access follow the same identity and access management controls as human users, including credential rotation and monitoring.
- ☐ Multi-factor authentication is required for administrative access to AI platforms.

Privacy & Individual Rights

- ☐ Individuals are notified when they are interacting with an AI system where required (this is a core transparency obligation under the EU AI Act's limited-risk tier, and increasingly required under U.S. state AI disclosure laws).
- ☐ A process exists to handle individual requests related to automated decisions, where applicable to the organization's regulatory footprint.
- ☐ Privacy impact assessments are performed for AI systems that process personal data at scale or make consequential decisions about individuals.

Monitoring

Governance does not end at deployment. NIST AI RMF's Manage function and ISO/IEC 42001's performance-evaluation clause both require ongoing monitoring proportional to risk.

- ☐ Production AI systems are monitored for performance degradation, drift, and anomalous outputs.
- ☐ A defined incident response procedure covers AI-specific failure modes (harmful output, data leakage, biased outcomes, prompt injection).
- ☐ Monitoring findings and incidents are reported to the accountable owner and, where material, to executive leadership.

- ☐ Internal audit or an equivalent independent function periodically tests whether documented AI governance controls are operating as designed.
- ☐ Metrics (e.g., number of AI systems inventoried, percentage risk-assessed, open remediation items) are tracked and reported on a recurring cadence.

Maturity Self-Score

Score each section on a 0–3 scale: 0 = not started, 1 = informal/ad hoc, 2 = documented but inconsistently applied, 3 = documented, applied, and monitored. Add the eight section scores for a total out of 24.

Section	0	1	2	3
Policy & Accountability				
Inventory & Use-Case Register				
Lifecycle Governance				
Risk Identification				
Risk Treatment				
Data Protection				
Access & Identity				
Privacy & Individual Rights				
Monitoring				
Total Score	Approximate Maturity Level		Typical Next Move	
0–7	Initial — ad hoc		Start with Phase 1 (Discover) of TSEC's AI Governance Roadmap	
8–15	Developing — partially documented		Formalize policy and close highest-risk gaps first	
16–20	Defined — documented company-wide		Focus on consistent monitoring and evidence collection	
21–24	Managed — documented, applied, and monitored		Consider ISO/IEC 42001 certification readiness	

Common Pitfalls

1. Treating the AI inventory as a one-time project rather than a living document — new tools appear faster than most organizations expect.
2. Writing a governance policy that is too broad to enforce, rather than starting with a short, specific acceptable-use policy for generative AI.
3. Assuming vendor-embedded AI features are the vendor's risk to manage, not the deploying organization's.
4. Applying the same level of scrutiny to every AI use case rather than tiering by risk, which causes low-risk requests to bottleneck the approval process.

5. Building technical controls before assigning an accountable owner, resulting in controls no one maintains after the initial rollout.

Recommendations

Organizations beginning this journey typically see the fastest risk reduction by sequencing work in the following order rather than attempting every control simultaneously:

6. Stand up the AI inventory first. You cannot govern what you cannot see, and most organizations underestimate how many AI-enabled tools are already in use.
7. Publish a short, enforceable acceptable-use policy for generative AI before building a full governance program — this closes the highest-velocity risk (shadow AI and uncontrolled data exposure) quickly.
8. Assign a single accountable owner for AI governance, even in organizations too small for a dedicated AI risk committee.
9. Layer in NIST AI RMF risk assessments for existing high-risk use cases before pursuing ISO/IEC 42001 certification — certification readiness follows naturally once the underlying controls are operating.
10. Fold AI vendor questions into existing third-party risk management rather than standing up a separate process.

Next Steps

This checklist establishes a baseline. Organizations that complete it typically move next to a formal AI risk assessment (see TSEC's AI Risk Assessment Checklist), a review of vendor and third-party AI exposure (see the AI Vendor Due Diligence Checklist), and a phased roadmap to close identified gaps (see the AI Governance Roadmap). Each of these resources is designed to be used together as a progression, not in isolation.

Sample AI Acceptable Use Policy Outline

Organizations without an existing policy to adapt often stall on drafting rather than content. Use the outline below as a starting skeleton for the Policy & Accountability section of this checklist — it is not a substitute for legal review, but it reflects the structure of policies that hold up under audit.

11. Purpose & Scope — what counts as an "AI system" for this policy, and which employees, contractors, and systems it applies to.
12. Accountable Roles — who owns AI governance decisions, and who approves Critical-tier use cases.

13. Approved Tools & Request Process — the current list of approved AI tools and the process to request evaluation of a new one.
14. Acceptable Use Rules — what data categories may never be submitted to which tiers of AI tool.
15. Intake & Approval Workflow — how a new AI use case gets proposed, assessed, and approved before production use.
16. Vendor & Third-Party Requirements — minimum due diligence expectations before adopting a vendor's embedded AI feature.
17. Monitoring & Incident Reporting — how employees report unexpected AI behavior, and how the organization monitors production systems.
18. Policy Review Cadence — how often the policy itself is reviewed and by whom.

Glossary of Key Terms

Term	Definition
AI System	Any software feature, model, or agent that uses machine learning, generative AI, or similar techniques to produce output, prediction, or action.
AIMS	AI Management System — the organizational structure defined by ISO/IEC 42001 for governing AI risk.
Confabulation	A generative AI model producing confident but factually incorrect output (also called "hallucination").
Consequential Decision	A decision affecting an individual's access to employment, credit, housing, healthcare, insurance, or government services.
Model Drift	Degradation in a model's accuracy or behavior over time as real-world data diverges from training data.
Residual Risk	The risk that remains after mitigating controls have been applied, which must be formally accepted by an owner.
Shadow AI	Use of AI tools for work purposes without organizational approval, visibility, or governance.

About TSEC & Next Steps

TSEC Risk & Cyber Advisory LLC helps SMBs, SaaS companies, FinTech, healthcare organizations, professional services firms, manufacturers, and government contractors build governance, risk management, and compliance programs that hold up under audit — and under real-world adversarial conditions. Our advisory work spans SOC 2, ISO 27001, NIST CSF, HIPAA, PCI DSS, NYDFS, and emerging AI governance requirements.

This resource is one part of a broader compliance library. Organizations that need help translating a checklist into an operating program — policies, control ownership, evidence

collection, board reporting, and audit readiness — typically engage TSEC for structured advisory support rather than building it alone.

Work With TSEC

Book a Strategy Call — a working session to review your current AI governance posture against NIST AI RMF and ISO/IEC 42001, and identify the highest-priority gaps.

Email: Info@tsecgrc.com

Web: www.tsecgrc.com

Visit www.tsecgrc.com/resources for the full compliance resource library

© 2026 TSEC Risk & Cyber Advisory LLC. This resource is provided for general informational and educational purposes and does not constitute legal advice. Organizations should consult qualified legal counsel to assess specific regulatory obligations.